

أوج — خطة التطوير والإطلاق الشاملة

من تجربة المستخدم إلى الإنتاج + الأمن + اختبار الكسر + MCP + Admin MCP

نسخة تنفيذية عملية — سبتمبر 2026

نطاق الوثيقة

هذه الخطة مخصصة لنقطة المشروع الحالية في مستودع rise-os. لا تعيد بناء ما تم إنجازه، بل ترتب الأعمال المتبقية والمطلوبة للوصول إلى تجربة مستخدم ناضجة، وأمان إنتاجي، وربط MCP حديث، وإطلاق قابل للمراقبة والرجوع.

1. نقطة البداية الفعلية للمشروع

تمت قراءة بنية المشروع الحالية من ملف المشروع المرفوع. المنصة مبنية كـ Next.js App Router مع React و TypeScript و Tailwind و Zustand و Radix/shadcn و TanStack Query، مع Supabase كمصدر بيانات أساسي، و Turso/Cloudinary/Upstash بحسب الاستخدام الحالي. توجد بالفعل طبقات مصادقة، rate limiting، RLS، اشتراكات، Admin Dashboard، Web Push، Community، audit logs، MCP قائم.

ملاحظة مهمة: بعض الوثائق الداخلية القديمة تحمل إشارات لتقنيات لم تعد مطابقة للتنفيذ الحالي، لذلك هذه الخطة تعتبر الكود الفعلي هو المرجع الأول، ثم تُحدَّث الوثائق لتطابقه.

المحور	الوضع الحالي	المعنى في الخطة الجديدة
واجهة التطبيق	Next.js 16 + React 19 + Tailwind 4	إعادة تنظيم UX بدون إدخال UI kit إضافي
البيانات	Supabase أساسي	الحفاظ على المصدر الواحد للتحقيق، مع تحسين الاستعلامات
Community media	Cloudinary	يبقى مع presigned upload وتعطيل أي أسرار في المتصفح
Rate limiting	Upstash	يبقى؛ نضبط حدوداً حسب الحساسية بدل حد عام مكلف لكل قراءة
MCP	موجود للمستخدم Max + Bearer/OAuth paths	ترقية للمواصفة الحديثة + صفحة MCP + JSON + Claude Code
Admin	لوحة إدارة منفصلة وظيفياً	إضافة Admin MCP منفصل أمنياً وبهوية server مختلفة
QA	Playwright + اختبارات كسر موثقة	تحويلها إلى بوابة إطلاق متعددة الطبقات

2. مبادئ غير قابلة للتفاوض

- أوج ليس Task Manager؛ واجهة اليوم يجب أن تجيب: ماذا أفعل الآن؟ أين أنا ذاهب؟ وهل أتقدم فعلاً؟
- الكشف التدريجي: لا نعرض كل الوحدات دفعة واحدة. نحافظ على كل القدرات لكن نجعلها تحت عوالم واضحة.
- اليوم هو العمود الفقري: Morning → Day → Focus → Review، وكل وحدة تغذي هذا المسار بدل أن تعيش منفصلة.
- الأمان خادمي أولاً: الواجهة لا تمنح صلاحية، و user_id القادم من العميل لا يُعتمد به في الملكية.
- لا أسرار في العميل: مفاتيح MCP، أسرار الخدمات، service role، ومفاتيح التوقيع لا تغادر الخادم.
- أي تغيير وظيفي كبير يمر عبر unit/API/E2E/security regression، وليس عبر نجاح build فقط.
- لا نضيف مكتبات جديدة إلا عند وجود سبب UX/أداء/أمان واضح؛ المشروع بالفعل غني بالمكتبات.

3. ترتيب التنفيذ الكامل

الأولية	المخرج الرئيسي	المحور	المرحلة
P0	خريطة التجربة + IA + Design rules	UX Foundation	16
P0	مركز القيادة + يوم موحد	Home & My Day	17
P0	تنقل 5 نقاط + عوالم	Navigation & Explore	18
P0	توحيد بصري حسب طبيعة كل وحدة	Core Modules	19
P0	رحلة أول دخول + تسجيل احترافي + consent	Onboarding + Auth	20
P1	XP + Daily/Weekly Review بدون ضغط	Progress & Reviews	21
P1	مجتمع نمو وتعلم	Community	22
P1	قصة تسويقية + Preview + Pricing	Landing + Conversion	23
P1	حدود + إعلانات محسوبة + upgrade UX	Monetization + Ads	24
P0	تقليل الطلبات والاستعلامات + caching	Performance & Data	25
P0	ترقية MCP الحديث + صفحة + JSON + Claude Code	MCP User Server	26
P0 Security	خادم وأدوات وصلاحيات وسجلات منفصلة	Admin MCP مستقل	27
P0 Security	ASVS/API/WSTG threat model + hardening	Security Hardening	28
P0	CI gates + regression + E2E matrix	Automated QA	29
P0	كسر متعمد + DAST + API abuse + MCP abuse	Break & Pen Test	30
P0	التنبيه + backups + rollback	Observability + DR	31
P0	20-5 ثم 50-20 مستخدم	Closed Beta	32
P0	الدومين + GSC + AdSense + فتح تدريجي	Public Launch	33
P1	قياس وتحسين بدون تدمير UX	First 30 Days	34

قرار معماري

لا Neon في البنية الحالية. Supabase يبقى مصدر الحقيقة. لا نضيف Cloudflare Workers أو بنية ثانية لمجرد "الكبر"؛ تضاف فقط عندما تكون هناك حالة استخدام مقاسة.

المرحلة 16 – تثبيت UX Foundation

الهدف: تحويل أفكار UX إلى نظام قرارات مكتوب قبل تعديل الكود.

التقنيات/الأدوات: Figma/whiteboard عند الحاجة، screenshots من التطبيق الحالي، Design tokens الحالية، analytics المتاحة.

التاسكات الصغيرة

□ حصر الشاشات الأساسية: Home، Explore، My Day، Community، Account، Login/Signup، Landing، Pricing، MCP.

□ رسم user journeys: مستخدم جديد، مستخدم يومي، مستخدم تعلم، مستخدم يريد Focus، مستخدم Max يريد MCP.

□ تعريف 4 عوالم: أنجز، تطور، توازن، إدارة حياتي.

□ تعريف 5 نقاط تنقل للهاتف: الرئيسية، استكشف، +، المجتمع، حسابي.

□ تعريف قاعدة: لا يظهر أكثر من 6 عناصر أساسية في السياق الواحد قبل "المزيد".

□ تعريف حالات empty/loading/error/success لكل شاشة أساسية.

□ كتابة UX copy rules باللهجة/العربية المستخدمة في المنتج بدون مبالغة تسويقية.

□ تعريف accessibility rules: focus states، keyboard، contrast، aria labels، reduced motion.

الاختبارات والتحقق

□ اختبار تنقل يدوي على هاتف + سطح مكتب.

□ اختبار screen reader أساسي للشاشات الجديدة.

□ مراجعة عدد clicks للهام الأساسية: إضافة مهمة، بدء Focus، تسجيل عادة، كتابة يومية.

بوابة إغلاق المرحلة

توجد خريطة UX نهائية، ولا يوجد تعارض بين Home/Explore/My Day/Modules، ويمكن تنفيذ الواجهة بدون قرارات UX معلقة.

المرحلة 17 – Home + My Day

الهدف: إنشاء مركز قيادة هادئ يحول كل البيانات المتناثرة إلى صورة يومية واحدة.

التقنيات/الأدوات: Zustand، Next.js client/server components، للواجهة، TanStack Query للبيانات، Framer Motion بحدود،

Recharts فقط عند الحاجة.

التاسكات الصغيرة

Home hierarchy: Greeting → Focus of the Day → Today snapshot → Continue → Quick actions → Progress → إعادة بناء ☐

.Discover

☐ إنشاء "My Day timeline" تجمع task/habit/focus/routine/planner items حسب الوقت.

☐ إضافة Quick Add عبر bottom sheet على الهاتف و command/popover على سطح المكتب.

☐ إضافة Continue where you left off من التعلم/القراءة/المشروع.

☐ حصر التحميل الأولي على البيانات المطلوبة فوق fold؛ أي شيء ثانوي lazy.

☐ بناء حالات user state: جديد، يوم فارغ، يوم مزدحم، مساء، مستخدم تعلم-focused.

☐ منع guilt copy: لا "فشلت" ولا red overload؛ استخدام "المتبقي" و "الفرصة التالية".

الاختبارات والتحقق

☐ Playwright: Home loads for new/returning user

☐ Playwright: Quick Add creates one entity without duplicate request

☐ Visual regression للـ Home mobile/desktop

☐ قياس LCP و TTFB و طلبات أول render قبل/بعد.

بوابة إغلاق المرحلة

Home تعمل كمرکز قيادة مستقل ويمكن للمستخدم فهمه يومه خلال ثوانٍ بدون فتح 5 وحدات.

المرحلة 18 – Navigation + Explore

الهدف: تقليل حمل الاختيار مع الحفاظ على كل الوحدات.

التقنيات/الأدوات: Vault، Existing Sidebar + responsive CSS فقط لو احتجنا bottom sheet فعلياً، cmdk للـ command menu.

التاسكات الصغيرة

☐ تحويل Sidebar إلى grouped worlds مع section labels واضحة.

☐ إنشاء Explore Hub يعرض العوامل بدل شبكة +20 module.

☐ إضافة search/command يفتح أي وحدة مباشرة بدون جعل القائمة الأساسية طويلة.

☐ تثبيت حالات active/back/breadcrumb للهواتف.

☐ إخفاء العناصر غير الأساسية داخل "المزيد".

☐ توحيد أسماء الوحدات بين analytics events، routes، nav،

الاختبارات والتحقق

Test كل route direct load + refresh + back/forward ☐

Test keyboard navigation للSidebar/Explore/Command ☐

Test RTL/desktop/mobile ☐

بوابة إغلاق المرحلة

لا توجد وحدة مفقودة من مسار الوصول، ولا المستخدم محتاج يحفظ أسماء 20+ وحدة.

المرحلة 19 – إعادة تشكيل الوحدات الأساسية

الهدف: الحفاظ على شخصية كل وحدة بدل تحويل كل شيء إلى نفس card grid.

التقنيات/الأدوات: Components الحالية + tokens مشتركة + dnd-kit حيث يفيد، Recharts عند الضرورة.

التاسكات الصغيرة

Tasks: list/timeline + priorities + Today ☐

Projects: board/cards + progress ☐

Goals: progress and milestones ☐

Habits: calendar/streak rings ☐

Learning: course/resource cards + continue ☐

Reading: progress/session ☐

Deep Work: timer-first immersive screen ☐

Journal: writing-first بدون distractions ☐

Health/Finance: privacy-sensitive layouts، لا Ads داخل الإدخال. ☐

Calendar: unified view من مصادر البيانات بدون duplicate data source ☐

Analytics: charts تبدأ من aggregation وليس تنزيل records الختام. ☐

الاختبارات والتحقق

Per-module CRUD regression ☐

Idempotency regression لكل mutation ☐

Error/empty/offline states ☐

Performance smoke على أكبر lists ☐

بوابة إغلاق المرحلة

كل وحدة لها UX identity خاصة لكنها تستفيد من نفس navigation, typography, spacing, feedback patterns.

المرحلة 20 – Onboarding + Auth + Consent

الهدف: جعل إنشاء الحساب والدخول رسميين وآمنين وقابلين للتدقيق.

التقنيات/الأدوات: Supabase Auth + BFF cookies httpOnly + Zod validation + server-side consent table.

التاسكات الصغيرة

☐ إضافة مسارات واضحة /login و/signup إن لم تُثبت تجربة query-mode الأفضل، مع الحفاظ على backward compatibility.

☐ إضافة Terms + Privacy checkbox إلزامي في signup مع روابط واضحة.

☐ إنشاء user_consent: user_id، consent_type، policy_version، consented_at، minimal metadata.

☐ رفض التسجيل خادماً إذا لم يتم قبول النسخة المطلوبة.

☐ إظهار password requirements indicator بشكل واضح.

☐ معالجة email confirmation/resend/reset-password بحالات UX واضحة.

☐ تأكيد عدم وضع session/token في localStorage.

☐ ضبط logout من كل الأجهزة عند الحالات الحساسة عند الحاجة.

☐ تحديث Security/Privacy docs لتتطابق providers الحقيقيين.

الاختبارات والتحقق

☐ Playwright auth state على حسابات اختبار مع حفظ auth state خارج git.

☐ CSRF/session expiry tests/401/403

☐ Consent acceptance + refusal + policy version update tests

☐ Account deletion/export regression

بوابة إغلاق المرحلة

لا يمكن إنشاء حساب بدون consent صحيح، ولا يوجد token حساس في browser storage، وكل auth flows لها حالات نجاح وفشل مكتملة.

المرحلة 21 – Progress + Daily/Weekly Review

الهدف: تحويل البيانات إلى إحساس تقدم بدون gamification ضاغط.

التقنيات/الأدوات: Existing XP/daily_scores + lightweight charts + rules engine بسيط على الخادم/العميل بدون AI.

التاسكات الصغيرة

□ بناء daily progress bar يوضح اليوم لا "قيمة الشخص".

□ XP يظهر كتعزيز ثانوي وليس كهدف أساسي.

□ Daily review: الإنجازات، mood، ملاحظة، next step.

□ Weekly review: goals، habits، focus، learning، highlight، improvement.

□ إضافة no-shame states عندما يكون اليوم ضعيفاً.

□ منع streak reset messaging العدواني.

الاختبارات والتحقق

□ اختبار حسابات progress عبر edge cases.

□ اختبار timezone/date boundaries.

□ اختبار عدم ظهور بيانات خاصة في analytics UI.

بوابة إغلاق المرحلة

المستخدم يقدر يراجع أسبوعه في أقل من دقائق بدون فتح كل وحدة يدوياً.

المرحلة 22 – Community كمساحة نمو

الهدف: جعل المجتمع امتداداً لهوية أوج وليس نسخة من Facebook.

التقنيات/الأدوات: Current community APIs + Cloudinary + moderation + notifications + pagination.

التاسكات الصغيرة

□ Feed tabs: لك، الشائع، الجديد.

□ Post types: إنجاز، سؤال، تعلمت، تجربة، نصيحة/نقاش.

□ Composer prompt: ماذا تعلمت اليوم؟

□ Profiles تعرض interests/achievements/progress signals بدل vanity metrics الثقيلة.

□ إضافة mute/block UX بوضوح.

□ الحفاظ على report/moderation/bans والaudit.

□ عدم auto-publish لأي بيانات خاصة من Home/Goals/Health/Finance

□ اختبار ranking بسيط: freshness + engagement rules بدون AI

الاختبارات والتحقق

□ Abuse tests: spam, repeated posts, oversized payloads, XSS text

□ Authorization matrix: owner/mod/admin

□ Pagination consistency and duplicate item tests

□ Media upload signature expiry/ownership tests

بوابة إغلاق المرحلة
المجتمع يضيف قيمة تعلم/مشاركة ولا يسرّب أبداً بيانات حياة خاصة.

المرحلة 23 – Landing + Conversion

الهدف: تحويل landing من showcase كبير إلى قصة تحويل واضحة وصادقة.

التقنيات/الأدوات: lazy images، real UI previews، metadata/JSON-LD، Next.js server rendering.

التاسكات الصغيرة

□ Hero: كل حياتك في مكان واحد من غير ما تحول يومك لمجموعة جداول.

□ إضافة section: لماذا أوج مش مجرد تطبيق مهام؟

□ شرح 4 life worlds بدل البدء بقائمة +20 وحدة.

□ Interactive product preview: Today/Habits/Focus/Goals

□ Pricing: Free / Plus / Max بنفس الوعود الفعلية في الكود.

□ FAQ واقعي، بدون claims غير موجودة.

□ روابط Features/Pricing/About/Contact/Legal

□ تحديث SEO: canonical، sitemap، robots، OG، schema، internal links

الاختبارات والتحقق

□ Page performance Lighthouse smoke

□ Accessibility headings/landmarks

□ JSON-LD validation

.Check mobile CTA visibility ☐

بوابة إغلاق المرحلة

الlanding تقول نفس الحقيقة التي ينفذها المنتج، وتحصل على Core Web Vitals وaccessibility مقبولة قبل الإعلان عنها.

المرحلة 24 – الاشتراكات والإعلانات

الهدف: حماية تجربة Free وتحويل الحدود إلى upgrade moments مفيدة لا مزعجة.

التقنيات/الأدوات: Existing plan_entitlements/consume_usage + ads config + AdSense/house ads + analytics events

التاسكات الصغيرة

☐ تثبيت Free/Plus/Max entitlement matrix في مصدر واحد.

☐ عرض ad placement على Home/Community/Tasks فقط عند الملاءمة.

☐ حد أقصى إعلان واحد بصرياً لكل شاشة.

☐ حجز مساحة الإعلان لمنع layout shift

☐ عدم عرض الإعلانات في onboarding، forms، timer، journal، health/finance sensitive actions

☐ جعل upgrade CTA يظهر عند اصطدام المستخدم بحد حقيقي فقط.

☐ إضافة cooldown لتكرار upgrade prompts

☐ إضافة analytics events: ad_impression، ad_click، upgrade_view، upgrade_click، upgrade_success

☐ تدقيق NPA/personalization وconsent

الاختبارات والتحقق

☐ Plan gate tests Free/Plus/Max

☐ Ad visibility tests by route and consent state

☐ No-ad sensitive screen test

☐ Usage race-condition tests around consume_usage

بوابة إغلاق المرحلة

Free usable، والإعلانات محدودة وواضحة، والpaid benefits هي المحرك الأساسي للقيمة.

المرحلة 25 – Performance + Data Efficiency

الهدف: تقليل تكلفة Supabase والlatency وعدد الطلبات قبل توسيع المستخدمين.

التقنيات/الأدوات: Turso، aggregate cache، SQL RPC، Upstash، TanStack Query، Next.js caching فقط حيث يعطي فائدة مقاسة.

التاسكات الصغيرة

□ إزالة أو تقليل select(*) واستبداله بـ DTO column lists.

□ خفض Dashboard الذي يجمع تقريباً 16 DB queries وتحويل ما يصلح إلى aggregate/RPC.

□ استبدال totalFocusMin للـ SQL aggregates بـ focus sessions limit=1000.

□ إضافة date/limit pagination لكل list غير الضروري أن يكون unbounded.

□ إعادة تصميم search بحيث يستخدم endpoint موحد أو server-side search بدل ضرب 6 endpoints لكل keystroke.

□ إبقاء GET dedupe/micro-cache مع invalidation دقيقة بعد mutations.

□ قياس Upstash cost/latency وعدم تطبيق Redis على كل read غير حساس بلا سبب.

□ تقييم Turso read mirror للمجتمع بناء على metrics وليس افتراضاً.

□ حصر payloads وتجنب تنزيل بيانات حساسة لا تُعرض.

الاختبارات والتحقق

□ قبل/بعد: request count، DB query count، response size، TTFB، p95 latency.

□ Load smoke على dashboard/community/tasks.

□ Regression on cache invalidation بعد mutation.

بوابة إغلاق المرحلة

أهم الشاشات تصل للبيانات المطلوبة بأقل عدد طلبات مع عدم كسر العزل أو freshness.

المرحلة 26 - MCP للمستخدم - Server حديث + صفحة MCP + JSON + Claude Code

الهدف: جعل MCP للمستخدم نقطة تكامل مستقرة وقابلة للنسخ إلى أي عميل MCP، مع دعم حديث للمواصفة الحالية والتوافق الخلفي عند الحاجة.

التقنيات/الأدوات: OAuth 2.1/PKCE، Streamable HTTP stateless، MCP 2026-07-28 عند المسار التفاعلي، Bearer API keys.

.Zod/JSON Schema، Claude Code .mcp.json.

التاسكات الصغيرة

- فصل endpoint العام للمستخدم عن أي endpoint إداري نهائياً.
- ترقية implementation لدعم MCP 2026-07-28 حيث يدعم SDK/infra، مع fallback للنسخ الأقدم الضرورية للعملاء الحاليين.
- إضافة server/discover capability أو negotiation equivalent وفق SDK/transport المستخدم.
- مراجعة headers الحديثة MCP-Protocol-Version / Mcp-Method / Mcp-Name والتحقق من اتساقها مع body عندما يكون المسار الحديث مستخدماً.
- تعريف tool catalog رسمي: read tools، write tools، destructive tools (إن أضيفت مستقبلاً).
- تحديد read/write scopes بدل صلاحية "كل شيء" بمفتاح واحد في المستقبل القريب.
- تثبيت human-in-the-loop لعمليات حساسة، وعدم السماح بالحذف اقتراضياً.
- إنشاء صفحة mcp/ داخل الإعدادات أو صفحة عامة مخصصة للتكامل: الحالة، الخطوة، endpoint، طرق الربط، revoke/rotate.
- إضافة تبويب "Claude Code" يشرح الربط بالمشروع عبر mcp.json أو claude mcp add-json.
- إضافة تبويب "JSON" به configuration جاهز للنسخ، بدون وضع secret ثابت في الصفحة؛ المفتاح يضاف محلياً من المستخدم.
- إضافة تبويب "ChatGPT" للإبقاء على التكامل الحالي، لكن جعله مجرد أحد adapters وليس التصميم الوحيد.
- إتاحة "Regenerate / Revoke" لمفتاح MCP وتسجيل العملية في audit.
- إضافة client_name / last_used_at / created_at / revoked_at للمفاتيح، دون تخزين المفتاح الخام.
- عدم استخدام GET query string لإرسال bearer secret في روابط قابلة للتسجيل إلا عند legacy flow اضطراري ومحدود؛ الأفضل Authorization header/OAuth.

الاختبارات والتحقق

- Protocol conformance: discover/tools/list/tools/call/errors
- Auth: expired/revoked/wrong plan/wrong user
- Header consistency tests for modern protocol
- JSON config parse test
- Claude Code config smoke using project .mcp.json in a fixture project
- Rate limits read/write and abuse burst
- Write audit event includes user, tool, request id, result class — no secrets

بوابة إغلاق المرحلة

المستخدم Max يدخل صفحة MCP وينسخ JSON جاهز أو يتبع Claude Code أو ChatGPT، مع security واضح، ويمكنه revoke/rotate بدون دعم يدوي. هذه المرحلة لا تمنح Admin capabilities للمستخدم إطلاقاً.

شكل صفحة MCP المقترحة

المحتوى	جزء الصفحة
Connected / Not connected / Revoked + آخر استخدام	Status
رابط MCP فقط + زر نسخ	Endpoint
Read / Write / Sensitive permissions حسب التصميم	Access
Claude Code / JSON / ChatGPT	Clients
Generate / Copy once / Rotate / Revoke	Key
ما يستطيع العميل فعله + ما لا يستطيع فعله	Safety
آخر 10 عمليات MCP مع tool name والوقت وحالة التنفيذ	Activity

```
{
  "mcpServers": {
    "awj": {
      "type": "http",
      "url": "https://awj.life/mcp"
    }
  }
}
```

.أو آلية البيئة التي يدعمها العميل secret store يوضع التوكن خارج المستودع/في #
ملاحظة: صيغة JSON النهائية يجب أن تطابق الـ MCP client المستهدف. الفكرة في الخطة هي تقديم configuration قابل للنسخ، مع طريقة آمنة لإمداد الاعتماد، وليس وضع secret داخل ملف يتم commit له.

المرحلة 27 – Admin MCP – خادم منفصل بالكامل

الهدف: بناء MCP إداري مستقل عن MCP المستخدم، بحيث لا توجد أي أداة أو صلاحية Admin مشتركة مع server المستخدم.
التقنيات/الأدوات: Endpoint/domain/path مستقل، auth مستقل، tool registry مستقل، rate limits مستقلة، audit stream مستقل، secrets منفصلة، allowlist/role checks مستقلة.

التاسكات الصغيرة

- ☐ اختيار endpoint مستقل مثل api/rise/admin-mcp/ أو نطاق فرعي مستقل حسب deployment النهائي.
- ☐ إنشاء server identity منفصلة: name مثل awj-admin-mcp و version منفصل.
- ☐ إنشاء namespace/tool registry منفصل، ولا تستورد أدوات المستخدم داخل Admin MCP registry.
- ☐ عدم قبول user MCP keys على Admin MCP إطلاقاً.
- ☐ إضافة Admin MCP credentials مستقلة، ويفضل short-lived/OAuth أو service credential مربوط بالأدمن + device/client identity.
- ☐ اشتراط requireAdmin على مستوى transport/application layer وليس داخل كل tool فقط.

□ إضافة role/permission matrix دقيقة: users.read، users.suspend، subscriptions.manage، community.moderate، ads.manage،

feedback.manage، audit.read، system.maintenance، system.read... حسب الأدوات المطلوبة.

□ فصل rate limits إلى namespace/admin limits أقوى وأشد.

□ تسجيل كل admin tool call في audit مع request id، reason، tool، target، actor.

□ عمليات عالية الخطورة: storage operations، broadcast، billing changes، key revoke، user delete/disable، maintenance toggle تحتاج

confirmation policy.

□ منع Admin MCP من إرجاع bulk PII افتراضياً؛ استخدم pagination/field allowlists/redaction.

□ منع أي tool من الوصول إلى service_role secrets أو قراءة app_config secrets مباشرة.

□ إضافة kill switch لـ Admin MCP من config server-side، مع fail-closed عند تعطل auth.

□ إنشاء صفحة MCP → Admin تعرض status، connected clients، scopes، rotate/revoke، activity، emergency disable.

□ إنشاء اختبارات تقول صراحة: admin valid → success، Free/Plus → 403، User session → 401، User MCP key → 401/403 فقط.

الاختبارات والتحقق

□ Cross-server isolation tests.

□ Privilege escalation attempts.

□ Horizontal admin target access tests.

□ PII overexposure tests.

□ Admin action audit coverage 100%.

□ Kill-switch test.

□ Key rotation/revocation propagation.

بوابة إغلاق المرحلة

يمكن إثبات رياضياً/اختبارياً أن MCP المستخدم لا يصل لأي Admin tool، وأن Admin MCP لا يقبل credential عادي، وكل فعل إداري حساس له audit + authorization + confirmation.

لماذا الفصل الكامل مهم؟

MCP أدواتها model-controlled؛ لذلك أي خطأ في tool registry أو authorization قد يتحول من bug إلى capability. نفصل server identity و credentials و registries و limits و audit حتى تصبح الحدود الأمنية واضحة وقابلة للاختبار.

Model

الهدف: تثبيت نموذج التهديد ثم إغلاق النقاط الحرجة قبل فتح المنتج للجمهور.

التقنيات/الأدوات: OWASP ASVS 5.0، OWASP API Security Top 10، OWASP WSTG، Zod، CSP، RLS، Upstash، CodeQL.

التاسكات الصغيرة

□ إنشاء threat model مختصر: assets، actors، trust boundaries، abuse cases، impact

□ بناء authorization matrix لكل route/API/tool/resource

□ مراجعة BOLA/Broken Object Level Authorization على كل endpoint يأخذ id

□ مراجعة Broken Function Level Authorization لكل admin route

□ مراجعة mass assignment / object property authorization

□ مراجعة rate limits لكل sensitive workflow وليس فقط login

□ مراجعة SSRF في أي remote URL/file import/integration

□ مراجعة API inventory: لا debug endpoints، لا legacy endpoints مكشوفة، لا versions متروكة بلا سبب.

□ مراجعة security headers/CSP/HSTS/frame/referrer/permissions

□ مراجعة session cookies: Secure/HttpOnly/SameSite + rotation/expiry

□ مراجعة logs: لا passwords، لا tokens، لا bearer keys، لا sensitive full payloads

□ مراجعة backup/export/delete flows كيانات حساسة.

□ تثبيت dependency policy: high/critical vulnerabilities لا تعد "warning" قبل الإطلاق إلا مع documented exception

الاختبارات والتحقق

□ ASVS checklist targeted على المهم، وليس copy/paste بدون تطبيق.

□ OWASP API Top 10 matrix لكل risk with evidence

□ WSTG scenarios على auth/session/input/error handling

□ ZAP baseline against staging

□ SAST CodeQL + dependency audit

بوابة إغلاق المرحلة

لا توجد ثغرات High/Critical مفتوحة بلا قبول مخاطر موثق، وكل API/admin/MCP boundary لها authorization evidence.

المرحلة 29 – Automated QA Gate

الهدف: تحويل الاختبارات من أداة مساعدة إلى شرط merge/release.

التقنيات/الأدوات: Playwright، TypeScript، ESLint، CodeQL، Bun audit، custom API tests، optional fast-check، GitHub Actions.

التاسكات الصغيرة

☐ إزالة continue-on-error من lint و security audit بعد تنظيف debt، أو تحويل الاستثناءات إلى allowlist مؤقتة بتاريخ انتهاء.

☐ تشغيل typecheck في كل PR.

☐ تشغيل build production-like في كل PR.

☐ إضافة Playwright smoke للـ auth/home/tasks/community/finance/learning/focus.

☐ إضافة API contract tests للـ 401/403/422/429/5xx.

☐ إضافة regression test لأي bug إنتاج سابق قبل إغلاقه.

☐ إضافة fixture users: anonymous/free/plus/max/admin/suspended.

☐ حماية secrets في CI و auth state خارج git.

☐ تفعيل artifact retention محدودة لنتائج الاختبارات.

الاختبارات والتحقق

☐ PR cannot merge on failing security-critical test.

☐ Nightly full E2E.

☐ Weekly dependency/security scan.

☐ Smoke after deploy.

بوابة إغلاق المرحلة

أخطاء النوع والبناء والـ security-critical regression تمنع الدمج؛ التحذيرات غير الحرجة فقط يمكن أن تبقى non-blocking بشكل مؤقت.

المرحلة 30 – Break Test + Pen Test – كسر الموقع عمدًا

الهدف: محاكاة مهاجم حقيقي على staging مع قواعد واضحة وإعادة اختبار بعد الإصلاح.

التقنيات/الأدوات: OWASP WSTG، OWASP ZAP، Playwright/API scripts، Burp/HTTP client، custom fuzzing، MCP abuse harness

التاسكات الصغيرة

□ تعريف قواعد الاختبار: staging فقط، test accounts فقط، snapshots/backups قبل الاختبار، stop conditions

□ Authentication attacks: invalid tokens، stale cookies، session fixation، reset abuse، signup abuse

□ Authorization attacks: ID swap، user_id tampering، cross-tenant reads/writes، admin route probing

□ Input attacks: XSS، HTML injection، SQLi-like payloads، JSON pollution، oversized input، unicode/RTL edge cases

□ Business logic: duplicate mutation، replay، double spending/usage، rate-limit bypass، race conditions

□ Community: spam، comments abuse، report abuse، media ownership، ban bypass

□ Ads/plan: Free trying to invoke Max-only APIs، direct endpoint access، usage bypass

□ MCP user: wrong plan، key reuse، revoked key، tool discovery، malformed JSON-RPC، batch abuse، write burst، tool

confusion

□ Admin MCP: user credential against admin endpoint، low-privilege admin role trying high-risk tool، target user swap، bulk PII

extraction، audit tampering

□ Infrastructure: robots/debug files، source maps exposure policy، env leakage، headers، CORS، TLS checks

□ Run ZAP baseline; then targeted active/manual tests on staging

□ فتح ticket لكل finding مع evidence، exploit steps، fix، retest evidence، severity

□ إعادة اختبار كل Critical/High وكل finding متعلق بـauth/admin/MCP بعد الإصلاح.

الاختبارات والتحقق

□ +50 attack cases minimum baseline، مع زيادة العدد حسب attack surface

□ Critical open 0

□ High open unless formally risk-accepted with compensating control 0

□ No auth bypass، no tenant escape، no admin escalation، no secret disclosure

□ ZAP baseline clean or all findings triaged

بوابة إغلاق المرحلة

الموقع ينجح في attack matrix الموثقة، ولا يوجد طريق من مستخدم عادي إلى بيانات مستخدم آخر أو صلاحيات Admin/MCP Admin.

قائمة كسر أساسية مقترحة

المجال	أمثلة كسر	Expected
Auth	expired cookie / forged JWT / wrong bearer	401
Tenant	change object ID / user_id	no data + 403/404
Admin	user calls admin route	403
Plans	Free calls Max-only tool	403
Rate limit	burst 100 calls	Retry-After + 429
Idempotency	same key repeated	same result / no duplicate
CSRF	cross-origin mutation	rejected
XSS	script/html payload in post/journal	stored/displayed inert
SQLi	quotes/union-like payloads	treated as text
MCP	unknown tool / malformed schema	protocol error, no side effect
MCP Admin	user MCP key → admin endpoint	401/403
Secrets	inspect HTML/logs/error	no key/secret
PII	bulk admin read without scope	blocked/redacted
Recovery	rollback after bad deploy	service returns healthy

المرحلة 31 – Observability + Backup + Disaster Recovery

الهدف: معرفة ما يحدث في الإنتاج والرجوع بسرعة عند الخطأ.

التقنيات/الأدوات: Existing error_logs/audit_logs + Vercel logs + Supabase backups + scheduled jobs + optional structured telemetry.

الناسكات الصغيرة

☐ تحديد production health KPIs: 5xx rate، auth failures، 429 rate، DB latency، MCP errors، notification failures

☐ تعريف alert thresholds بدل مراقبة dashboard يدوياً فقط.

☐ تثبيت request/correlation ID عبر MCP/admin MCP/API.

☐ إخفاء PII/secrets من logs.

☐ تشغيل backup cadence موثق + restore drill.

☐ كتابة rollback procedure: Vercel rollback + DB migration discipline.

☐ تعريف migration policy: forward migration، rollback strategy، destructive migrations separate.

☐ إضافة emergency controls: maintenance mode، disable MCP، disable Admin MCP، disable community media upload، disable ads.

الاختبارات والتحقق

.Restore drill from actual backup ☐

.Rollback drill on staging ☐

.Alert test with synthetic error ☐

.MCP disable/re-enable test ☐

بوابة إغلاق المرحلة

يمكن اكتشاف خطأ حقيقي، إيقاف capability حساسة، استعادة backup، والعودة لنسخة سليمة بدون تخمين.

المرحلة 32 – Closed Beta

الهدف: اختبار المنتج مع 5-20 مستخدماً أولاً ثم التوسع تدريجياً مع مراقبة السلوك وليس الآراء فقط.

التقنيات/الأدوات: feedback، Feature flags/config داخل التطبيق، analytics، error logs، support playbook.

التاسكات الصغيرة

☐ بدء 5 مستخدمين ثم 10 ثم 20 بعد كل checkpoint.

☐ تسجيل أكثر 3 نقاط توقف في onboarding و Home و first-week usage.

☐ قياس activation: إنشاء أول task/habit/focus/journal أو استخدام مسار أساسي.

☐ قياس retention مبكر بدل vanity metrics.

☐ استخدام feedback categories: bug، confusing، missing، performance، safety.

☐ تثبيت 5 daily launch checklist دقائق.

☐ عدم فتح ميزات جديدة خلال beta إلا للإصلاح/الضروري.

الاختبارات والتحقق

☐ Zero blocker incidents across core flow.

☐ All critical feedback triaged within agreed window.

☐ Security smoke after each meaningful deploy.

☐ No unexplained 5xx spikes.

بوابة إغلاق المرحلة

أول cohort يمر من التسجيل إلى يوم كامل ثم أسبوع مع أخطاء مانعة صفر أو مقبولة رسمياً.

Public Launch — المرحلة 33

الهدف: فتح أوج للجمهور تدريجياً وبقابلية التراجع.

التقنيات/الأدوات: Vercel + Supabase + current providers، domain awj.life، GSC، AdSense

التاسكات الصغيرة

☐ ربط awj.life والتحقق من HTTPS/canonical/redirects.

☐ ضبط NEXT_PUBLIC_SITE_URL وكل callback/allowlist.

☐ ضبط Zoho MX/SPF/DKIM/DMARC إذا تم استخدام البريد الخارجي.

☐ Verify Google Search Console + sitemap.

☐ إكمال AdSense steps فقط بعد توافق consent/legal والمحتوى.

☐ فتح public traffic تدريجياً.

☐ متابعة error/latency/429/MCP/community metrics أول ساعات launch.

☐ تثبيت launch freeze: لا refactor كبير بعد فتح الجمهور.

الاختبارات والتحقق

☐ Production smoke in authenticated and anonymous states.

☐ Health endpoint and logs healthy.

☐ Rollback point tagged.

☐ Admin access verified.

☐ MCP user tested from a real client.

☐ Admin MCP disabled by default until explicitly enabled if not needed day one.

بوابة إغلاق المرحلة

أوج متاح على الدومين النهائي، والـ smoke tests والـ rollback والإشراف تعمل.

المرحلة 34 — أول 30 يوم بعد الإطلاق

الهدف: تحسين ما يثبت أنه يحسن تجربة المستخدم، وليس ما يرفع الأرقام فقط.

التقنيات/الأدوات: Analytics، feedback، error monitoring، controlled feature flags، release notes.

التاسكات الصغيرة

- ☐ مراجعة أسبوعية للـ activation/retention/errors/performance
- ☐ تحليل أكثر 5 workflow drop-offs
- ☐ قياس ad pressure مقابل upgrade success قبل زيادة أي ad slot
- ☐ قياس MCP adoption: connections، tool calls، errors، revokes
- ☐ تحديد 2-1 UX experiments فقط في كل دورة.
- ☐ لا تغيّر navigation الأساسية بسبب عينة صغيرة من المستخدمين.
- ☐ تحديث docs/architecture/status بعد كل release كبير.

الاختبارات والتحقق

- ☐ Week 1 / 2 / 4 reviews
- ☐ Regression after every experiment
- ☐ Security scan weekly

بوابة إغلاق المرحلة
كل تغيير له metric واضح وموعد مراجعة، ولا تتحول beta feedback إلى فوضى features.

4. بوابات الأمان الرسمية قبل كل Release

البوابة	ما الذي يجب أن ينجح؟	Block release؟
SAST	CodeQL no new critical/high exploitable finding	نعم
Dependencies	No unreviewed critical/high dependency vulnerability	نعم
Auth	All 401/403 matrix tests pass	نعم
RLS/Tenant isolation	No cross-user read/write	نعم
Admin isolation	No privilege escalation	نعم
MCP user	No auth/tool boundary bypass	نعم
Admin MCP	No cross-server/role bypass	نعم
DAST	ZAP baseline reviewed; critical/high blocked	نعم
E2E	Core user journeys pass	نعم
Backup/rollback	Recent restore/rollback evidence	نعم قبل public launch

5. Threat Model مختصر

Asset	الخطر الأكبر	الدفاع الأساسي
بيانات المستخدم الخاصة	BOLA / data leak	RLS + server ownership + tests
جلسات الدخول	token theft / session abuse	httpOnly + secure cookies + expiry/rotation
MCP user key	credential theft / over-privilege	hash at rest + revoke + scopes + rate limits
Admin credentials	total compromise	separate credential plane + least privilege + audit
Community media	unauthorized access / abuse	presign + ownership + content limits
Billing/limits	bypass / replay	server entitlement + DB lock/transaction + idempotency
Logs/backups	secondary data leak	redaction + restricted access + retention
Admin MCP	agent-driven destructive action	separate server + allowlist + confirmation + audit

6. سياسة إضافة المكتبات

المشروع الحالي فيه عدد كبير من الأدوات. لذلك الافتراضي هو عدم الإضافة. الإضافات المقبولة فقط عند وجود مكسب واضح في تجربة الاستخدام أو الأداء أو الأمان.

المكتبة	متى نستخدمها؟	قرار
Vaul	modal custom Bottom sheet mobile	مرشحة
Embla Carousel	Horizontal product previews/mobile sections	مرشحة
TanStack Virtual	قوائم ضخمة جداً فقط	حسب القياس
DiceBear	Avatars موحدة للمجتمع عند الحاجة	اختيارية
React Hook Form	نماذج معقدة جداً إذا زادت الحاجة	ليست مطلوبة الآن
GraphQL/tRPC/Redux/AI frameworks	لا حاجة حالية	مرفوضة لهذا المسار

7. Definition of Done لكل Task

☐ الكود في الطبقة الصحيحة ولا يكسر الفصل بين UI/controllers/data

☐ Validation server-side عند وجود input.

☐ Authorization server-side

☐ Idempotency لأي mutation المطلوبة.

☐ Unit/API/E2E test مناسب لحجم التغيير.

☐ لا logging لبيانات حساسة.

☐ Accessibility الأساسية مكتملة.

☐ لا regressions على mobile/desktop.

□ تحديث docs عند تغيير architecture/contract.

□ الحصول على build/typecheck/lint/security gate حسب المرحلة.

8. ترتيب يوم التنفيذ المقترح

لمنع التشتت أثناء التنفيذ، كل جلسة تطوير يجب أن تتبع هذا الترتيب:

الخطوة	المطلوب
1	اختيار phase واحدة فقط.
2	فتح 3-7 tasks صغيرة كحد أقصى.
3	تنفيذ أصغر task كاملة مع test.
4	تشغيل regression سريع.
5	commit واضح باسم phase/task.
6	تحديث PLAN_STATUS.
7	الانتقال للـ task التالية.

9. المصادر المرجعية التي بُني عليها مسار الأمان و MCP

المراجع التالية تم التحقق منها على الويب أثناء إعداد الوثيقة، وتستخدم كمرجع للقرارات التقنية لا كنصوص منسوخة:

- OWASP ASVS 5.0.0 — معيار التحقق الأمني للتطبيقات، الإصدار المستقر المنشور في 2025.
 - OWASP API Security Top 10 — خاصة BOLA، Broken Authentication، Property Authorization، Unrestricted Resource Consumption، Function Authorization، SSRF، Security Misconfiguration، Inventory Management، Unsafe Consumption.
 - OWASP Web Security Testing Guide (WSTG) — منهجية اختبار شاملة للـ configuration، business logic، input، session، auth وغيرها.
 - OWASP ZAP Baseline Scan — DAST/Passive baseline مناسب للإدخال في CI/CD مع ضرورة إجراء اختبارات نشطة/يدوية منفصلة للنطاق الحساس.
 - Playwright Authentication docs — حفظ auth state في مجلد اختبارات غير متبع وعدم commit ملفات الـ state الحساسة.
 - MCP Specification 2026-07-28 — الاتجاه الحالي للمواصفة: stateless core، Streamable HTTP، discovery، header-aware routing، authorization hardening، deprecation للمسار القديم HTTP+SSE.
 - Anthropic Claude Code MCP docs — المشروع يمكنه استخدام mcp.json و claude mcp add-json لربط MCP servers ضمن project scope.
- روابط مباشرة:

• [/https://owasp.org/www-project-application-security-verification-standard](https://owasp.org/www-project-application-security-verification-standard)

• [/https://api-security.owasp.org/editions/2023/en/0x11-t10](https://api-security.owasp.org/editions/2023/en/0x11-t10)

- [/https://wstg.owasp.org](https://wstg.owasp.org)
- [/https://www.zaproxy.org/docs/docker/baseline-scan](https://www.zaproxy.org/docs/docker/baseline-scan)
- <https://playwright.dev/docs/auth>
- [/https://blog.modelcontextprotocol.io/posts/2026-07-28](https://blog.modelcontextprotocol.io/posts/2026-07-28)
- <https://docs.anthropic.com/en/docs/claude-code/mcp>

10. Launch Gate النهائي – لا نشر قبل اجتيازه

المجموعة	الحالة المطلوبة
UX	Home + My Day + Explore + auth + core workflows مفهومة ومختبرة
Product	Free/Plus/Max و Community و notifications تعمل end-to-end
Security	ASVS/API/WSTG targeted review + break test + DAST
MCP	User MCP يعمل + JSON + Claude Code + ChatGPT path، مع isolation
Admin MCP	منفصل ومغلق حتى اكتمال الاختبارات + emergency kill switch
Performance	Dashboard/search/lists محسنة بأرقام before/after
QA	CI blocking gates + Playwright smoke + regression suite
Operations	backups + restore drill + rollback + monitoring
Legal	Terms/Privacy/Consent/Ads/Community texts محدثة
Production	awj.life + DNS + HTTPS + GSC + email deliverability checks

النتيجة المستهدفة

أوج يخرج كمنتج واحد متماسك: Home تقود اليوم، Explore تجمع العوالم، Community تدعم النمو، الاشتراك يفتح قيمة حقيقية، MCP يربط أدوات المستخدم الخارجية، وAdmin MCP يعيش في منطقة ثقة منفصلة تماماً. والأهم: كل هذا خلف اختبارات أمان وكسر يمكن إعادة تشغيلها، وليس “إحساس إن الموقع جاهز”.